ТРЕТЬЯ ИТЕРАЦИЯ · ОТЧЁТ 3.0

СОД Stream-CAD

Роадмап «Аудита 2.0» закрыт полностью: три волны в продакшене, девять фикс-коммитов команды поверх патчей, swipe-сравнение версий сверх плана. Осталось — зачистка: CDN, тесты на фиксы и десять мелочей.

Ревизия кода 6c997f2 · 2 ноября 2026

Аудитор: Z.ai · для руководства и команды Stream-CAD

Содержание

1. Резюме и вердикт 1

2. Хронология: как закрывался роадмап 2

3. Заслуги команды 3

4. Аудит нового кода: T65 и фиксы 4

4.1. T65: слайдер не отвечает пальцу 4

4.2. Права чтения: N+1 в горячем пути 4

4.3. PWA-слой: три разрыва дисциплины 4

4.4. Фиксы без регрессионных тестов 4

5. Остатки из Аудита 2.0 5

6. Роадмап 3.0: спринт зачистки 6

7. Инвентаризация поставок 7

1. Резюме и вердикт

Этот отчёт — третья итерация аудита интерфейса Среды общих данных (СОД) Stream-CAD. «Аудит 2.0» от 1 ноября 2026 года заканчивался роадмапом из трёх волн; проверка репозитория 2 ноября показывает, что роадмап закрыт полностью. На GitHub в ветке main лежат применённые патчи Спринта 1, Спринта 2 и Волны 3, поверх них команда выпустила две серии собственных исправлений (коммиты 200cf04 и 6c997f2) и добавила функцию, которой в роадмапе не было, — swipe-сравнение версий слайдером (T65). Прогресс первого аудита, зафиксированный на отметках «65% / 40% / 5%», превратился в закрытые 100% / 100% / 95%.

Качество цикла подтверждается измеримо: на ревизии 6c997f2 прогон Django-тестов даёт 284 из 284, системная проверка clean, незаложенных миграций нет. Единственная миграция цикла (issues.0006_notification) применена. Ограничения команды соблюдаются: Django + HTMX + vanilla JS, без React/SPA и Storybook. Отдельно отметим дисциплину команды: девять фикс-коммитов поверх патчей аудитора — включая три находки класса безопасности (formula injection в Excel-экспорте, утечка прав в реестре и в командной палитре) — это зрелый инженерный контур, а не пассивное потребление патчей.

3 из 3	9	284/284	15
волны роадмапа в продакшене	фикс-коммитов команды поверх патчей	тестов на ревизии 6c997f2	пунктов осталось на зачистку

Вердикт: продукт вышел из цикла системным. Три параллельные системы цвета консолидированы через tokens.json, reload-паттерны устранены, зоны ISO 19650 получили управляемый workflow с матрицей ролей, вьювер — кластеризацию маркеров и мини-карты, а PWA и командная палитра делают инструмент рабочим на планшете стройплощадки. Тем не менее проверка выявила две слабые зоны. Первая — новые риски в свежем коде: swipe-режим T65 не отвечает на touch-события (а PWA затеивался именно для площадки), сервис прав чтения содержит N+1-запросы, офлайн-страница выбивается из дисциплины токенов. Вторая — хвост из пятнадцати мелочей Аудита 2.0, включая CDN-зависимости, которые прямо противоречат PWA-стратегии офлайн-работы. Всё это собирается в «Спринт 3 · зачистка» (3–5 дней), описанный в разделе 6.

2. Хронология: как закрывался роадмап

За сутки между «Аудитом 2.0» и этой проверкой ветка main прошла путь от ревизии 8aff57e (только Спринт 1) до 6c997f2 — пять коммитов, каждый из которых можно проследить до пункта роадмапа. Порядок применения корректный: сначала фича, затем фиксы поверх неё, без смешивания в одну большую сборку. Такой ритм «патч → ревью-фиксы» стоит зафиксировать как процесс: он дал команде возможность поймать реальные дефекты в свежем коде до того, как они дошли до пользователей.

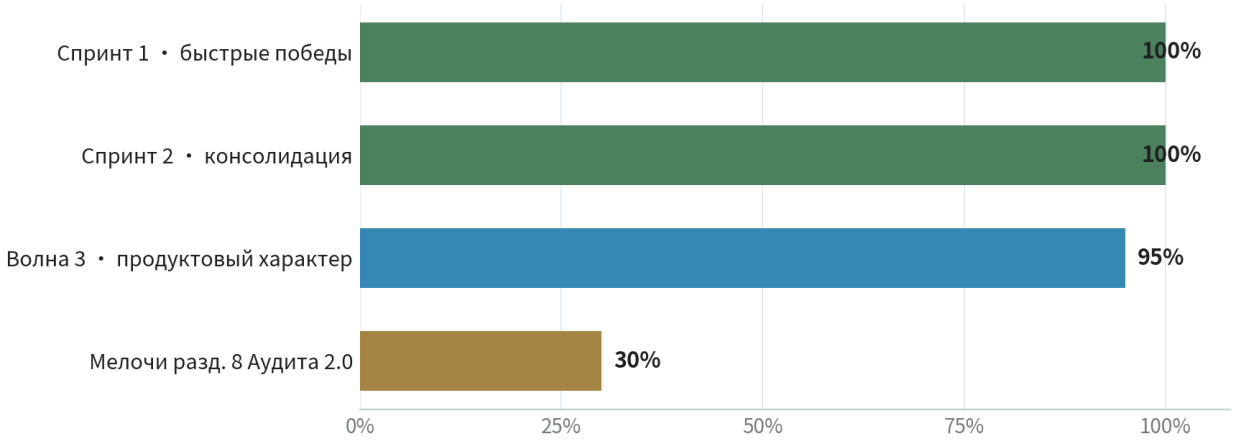


Рисунок 1 — Прогресс закрытия роадмапа «Аудита 2.0» на ревизии 6c997f2

Коммит	Что сделано	Источник
188ac46	feat(T65): swipe-сравнение версий слайдером — сверх роадмапа, с клавиатурным управлением разделителем	команда
1671fe6	feat: apply Sprint 2 — base.html, генератор токенов с CI, реестр замечаний с Excel, мини-карты, apply-on-change	патч аудита
200cf04	fix(sprint2): formula injection, права реестра, токены в Excel, urlencode, мини-карта в режиме сравнения	команда
7e01e89	feat: apply Wave 3 — зоны ISO 19650 и workflow, уведомления и «Мои замечания», кластеры маркеров, палитра, PWA	патч аудита
6c997f2	fix(wave3): утечка кэша SW, права палитры, офлайн-фолбэк, ограничение scope проверяющего	команда

Таблица 1 — Пять коммитов цикла 1–2 ноября 2026

3. Заслуги команды

Самая важная находка этой итерации — не в интерфейсе, а в процессе. Команда не просто применила патчи, а прочла их и поймала в них дефекты, которые аудитор пропустил. Три из девяти фиксов относятся к классу безопасности и заслуживают отдельного перечисления. Во-первых, formula injection: ячейки Excel-экспорта, начинающиеся с =, +, − или @, экранируются апострофом — без этого пользовательский текст замечания вида «=HYPERLINK(...)» исполнился бы в Excel у каждого, кто открыл реестр. Во-вторых, права реестра: выборка была ограничена доступом к проекту, но не проверяла право чтения конкретного документа — проверяющий видел замечания по чужим разделам. В-третьих, та же лазейка была в командной палитре: поиск по Ctrl+K показывал документы, читать которые пользователь не вправе.

#	Фикс команды	Суть	Класс
1	_safe_excel_value	экранирование =, +, −, @ в ячейках Excel-экспорта	безопасность
2	права реестра	проверка read-права каждого документа, а не только проекта	безопасность
3	права палитры	Ctrl+K ищет только по читаемым документам	безопасность
4	checker scope	проверяющий/нормоконтроль действуют только в своих проектах	безопасность
5	SW cache leak	из кэша сервис-воркера исключены /download/, /media/, /folders/	надёжность
6	offline-фолбэк	страница /offline/ вместо Response.error() при офлайне	надёжность
7	urlencode фильтров	корректная сборка query-строки реестра	качество
8	мини-карта в compare	мини-карта не конфликтует с режимом сравнения	качество
9	Excel из токенов	цвета шапки/гиперссылок — из design_colors, не hex	дисциплина

Таблица 2 — Девять фиксов команды поверх патчей аудита

Отдельного упоминания заслуживает T65 — swipe-сравнение версий слайдером. Функции не было ни в одном роадмапе, при этом реализована она аккуратно: разделитель управляется мышью и клавишами-стрелками с preventDefault, режим корректно выключает панорамирование, состояние сбрасывается при закрытии сравнения. Это ровно тот случай, когда команда знает пользовательский сценарий (наложить две ревизии одного листа) лучше формального списка пожеланий.

4. Аудит нового кода: T65 и фиксы

4.1. T65: слайдер не отвечает пальцу

Swipe-сравнение построено на событиях мыши: mousedown на разделителе, mousemove на window, плюс клавиатурные стрелки. Touch- и pointer-событий в коде нет — grep по touchstart/pointerdown возвращает ноль вхождений. На десктопе это незаметно, но противоречие с собственной стратегией очевидно: PWA и офлайн-оболочка делались «для площадки», а на планшете прораба разделитель не перетащишь пальцем. Исправление дешёвое: перевести обработчики на Pointer Events (pointerdown/pointermove/pointerup с setPointerCapture) — одна замена покрывает мышь, стилус и тач одновременно; при необходимости запретить прокрутку жестом уже готовым правилом touch-action: none.

4.2. Права чтения: N+1 в горячем пути

Фикс прав реестра и палитры введён через сервис get_readable_documents: queryset документов перебирается в Python, и для каждого документа вызывается check_read_permission — по запросу к базе на каждый чек на больших выборках. На проекте в сотню документов реестр выполнит сотню лишних обращений на каждый рендер таблицы, экспорт в Excel и каждый запрос палитры. Это осознанный компромисс корректности ради скорости выкатки, и он допустим на текущих объёмах, но масштаб плохо: рост числа документов линеен по времени отклика. Лекарство — кэшировать читаемые pk на запрос (например, через context processor или cached_property), либо перенести правило членства в SQL-аннотацию. Пока объёмы малы, достаточно первого варианта.

4.3. PWA-слой: три разрыва дисциплины

Офлайн-страница /offline/ — правильное решение, но свёрстана инлайновыми стилями с жёсткими hex-значениями (#F6F6F4, #191917, #2F5BEA), которых нет в tokens.json; акцентный синий вообще не из палитры проекта. Это ровно та болезнь «третьей системы цвета», которую весь прошлый цикл лечили. Второй разрыв — список bypass-префиксов сервис-воркера (/download/, /media/, /folders/) зашит вручную и будет дрейфовать с urls.py при каждом новом маршруте; у проекта уже есть готовый паттерн build_design_tokens.py — тот же генератор может отдавать sw-bypass-list.js. Третий — CACHE_NAME бампается руками (v3 → v4): при следующем изменении статики про него забудут, и пользователи получат устаревшую оболочку; версию стоит собирать из хэша файлов или из уже существующего ?v= бампера base.html.

4.4. Фиксы без регрессионных тестов

Счётчик тестов между ревизиями не изменился: было 284, стало 284. Ни formula injection, ни матрица прав, ни офлайн-фолбэк не покрыты проверками — то есть следующий рефакторинг может молча откатить эти исправления. Для каждого из четырёх security-фиксов тест пишется за 15–30 минут: подача текста «=CMD()» в описание и проверка экранирования ячейки, доступ проверяющего к чужому документу в реестре и в палитре, workflow-переход проверяющего в проекте без членства. Рекомендуемый минимум — четыре теста в issues/tests и один на сервис прав.

5. Остатки из Аудита 2.0

Роадмап закрыт не полностью: из разделов 6–8 «Аудита 2.0» выжило пятнадцать мелочей. Их суммарная цена невелика — это работа на один короткий спринт, но именно они формируют ощущение «сыровато» при первом заходе. Таблица ниже фиксирует судьбу каждого пункта; три из них (CDN, заглушка наложения, даты) обсуждаем подробнее, потому что они пересекаются с новыми функциями и усиливают друг друга.

Пункт из Аудита 2.0	Где	Статус
CDN: Google Fonts и bootstrap-icons	base.html:29, document_detail.html:11–12	остался
toggleOverlay — alert-заглушка наложения	pdf_viewer.js:2104	остался
Даты вразнобой d.m.Y / d.m.Y H:i	_card.html:48 и 154	остался
viewer.css: слои override T66/T67	viewer.css	остался
Водяной знак opacity 0,25	redesign.css:44	остался
Подсказка клавиш N/P в тултипах ‹ ›	document_detail.html:85–89	частично
«Последние документы» без метаданных	project_detail.html:18–27	остался
Плейсхолдер шифра «28-10-26-ТЕСТ»	project_list.html:76	остался
«Импорт/Экспорт/Настройки» в меню ⋯	_documents_panel.html:164–179	не начат
Пустые состояния без CTA	registry.html:186	частично

Таблица 3 — Судьба мелочей Аудита 2.0 на ревизии 6c997f2

CDN-зависимость стала противоречием, а не просто шумом: сервис-воркер кэширует оболочку, но не может закэшировать кросс-доменные шрифты и иконки надёжно, поэтому при потере сети планшет стройплощадки получит интерфейс с системным шрифтом и без иконок — ровно в том сценарии, ради которого PWA затевался. Самостоятельный хостинг двух файлов (woff2 Golos Text и bootstrap-icons) закрывает и офлайн, и «внезапно поехавшую» вёрстку. Заглушка toggleOverlay теперь ещё и конфликтует по смыслу с T65: рядом живут кнопка «наложение версий», которая показывает alert, и настоящий swipe-режим — пользователю непонятно, чем они отличаются. Правильное решение — убрать кнопку-заглушку и переименовать режим T65 в «Сравнение / наложение». Форматы дат «30.10.2026» и «01.11.2026, 17:43» нужно свести к единому табличному варианту с неразрывным пробелом — хелпер уже существует с первого спринта.

6. Роадмап 3.0: спринт зачистки

Дальше роадмап — это один короткий спринт зачистки (3–5 дней) и два необязательных направления роста. Приоритет P1 получают пункты, которые либо защищают уже сделанное (тесты на security-фиксы), либо чинят несоответствие продукта его собственной стратегии (тач для T65 на площадке, CDN против офлайна). P2 — устойчивость к росту: кэш прав, генерируемый bypass-список SW, версия кэша из хэша. P3 — косметика из таблицы 3. Условие выхода: тесты зелёные, офлайн-прогон на планшете без сети проходит с корректными шрифтами и иконками, а в тулбаре вьювера не остаётся ни одной кнопки-заглушки.

Приоритет	Пункт	Цена
P1	Pointer Events для T65: перетаскивание разделителя пальцем и стилусом	2–3 ч
P1	Четыре регрессионных теста на formula injection и матрицу прав	0,5 дня
P1	Локальный хостинг Golos Text и bootstrap-icons, удаление CDN-ссылок	2–3 ч
P2	Кэш читаемых pk на запрос; снять N+1 с реестра и палитры	0,5 дня
P2	Генерация sw-bypass-list.js из urls.py по паттерну build_design_tokens.py	2 ч
P2	Версия кэша SW из хэша статики вместо ручного бампа CACHE_NAME	1–2 ч
P2	offline.html из tokens.css: убрать инлайн-hex и «третий синий»	1 ч
P3	Убрать кнопку toggleOverlay; связать режим наложения с T65	1 ч
P3	Единый формат дат через хелпер: «30.10.2026, 13:41» с табличными цифрами	2 ч
P3	Водяной знак: opacity 0,25 → 0,12	5 мин
P3	Тултипы ‹ ›: упомянуть клавиши N и P	10 мин
P3	«Последние документы»: чипы с типом, версией и временем открытия	2–3 ч
P3	Системный плейсхолдер шифра проекта вместо «28-10-26-ТЕСТ»	10 мин
P3	«Импорт/Экспорт/Настройки» — свернуть в меню ⋯	1–2 ч
P3	Пустые состояния: CTA «создаётся кликом по листу», свернуть T66/T67	2–3 ч

Таблица 4 — Спринт 3 · зачистка: 15 пунктов, 3–5 дней

Направления роста после зачистки остаются теми же, что в «Аудите 2.0», но их приоритетность изменилась: e-mail-канал уведомлений стал актуальнее (сейчас колокольчик виден только внутри системы, а публикация документа — событие, которое должно догонять по почте), дайджест на почту руководителю проекта — естественное продолжение экрана «Мои замечания». Второе направление — журналирование workflow-переходов зон в аудит-лог ISO 19650: матрица ролей уже есть, осталось писать историю «кто, когда, из какой зоны в какую» с возможностью показать её в карточке документа.

7. Инвентаризация поставок

Все материалы цикла передавались пакетами и лежат у команды: «СОД_Спринт_2.zip» (README, патч, 24 файла, скриншоты), «СОД_Волна_3.zip» (README, два патча, 30 файлов, 7 скриншотов) и собранный после Волны 3 «СОД_Полный_пакет.zip», который объединяет отчёт «Аудит 2.0», пять патчей и оба комплекта файлов (76 файлов). Кумулятивный патч sod_sprint1+2+3_cumulative.patch переводит исходный репозиторий сразу в состояние Волны 3 и проверен применением на чистых клонах соответствующих ревизий. Настоящий отчёт закрывает третий цикл аудита; следующая проверка имеет смысл после «Спринта 3 · зачистка» — ожидаемый результат: ноль остатков из таблицы 3, пять новых тестов, офлайн-прогон на планшете.